

12 > Device hardening

certificate or public key, preventing man-in-the-middle (MITM) attacks even if a rogue CA is trusted by the system.

Understanding pinning concepts

- Static Pinning: Embed certificates or public keys within your app bundle.
- Dynamic Pinning: Retrieve pins securely from a trusted source at runtime.

Step-by-Step: Enabling pinning in third-party apps

1. Check app support

- Only some security-focused apps (e.g., banking, enterprise VPNs) offer built-in pinning. Consult the app's documentation or settings.

2. Use a managed configuration

- In an MDM environment, push a configuration profile that includes pinned certificate fingerprints for corporate apps.

3. Test your setup

- Use tools like Burp Suite configured as an HTTP proxy. If pinning works, your proxy's certificate will be rejected by the app.

Example: Acme Bank's iOS app embeds SHA-256 hashes for its backend's TLS certificate. During routine pentesting, the app refuses to connect when the tester's proxy presents a self-signed cert – confirming effective pinning.

Firewall tuning and network controls

A software firewall on your device lets you monitor and control inbound and outbound connections, blocking malicious traffic before it reaches sensitive apps.

Android: Local firewalls and traffic monitors

1. Install a firewall app

- Choose a reputable app such as AFWall+ (requires root) or NoRoot Firewall.



2. Configure per-app rules

- Block network access for apps that shouldn't use data (e.g., ad-heavy games).

3. Monitor logs

- Review connection attempts periodically to detect unusual outbound traffic patterns.

iOS: Network extensions and DNS filtering

1. Use DNS-based filtering

- In Settings → Wi-Fi → Tap “i” next to your network → Configure DNS → Manual → Add a trusted DNS server that supports filtering (e.g., NextDNS).

2. Leverage VPN-based firewalls

- Apps like Lockdown or Guardian Firewall use the Network Extension API to provide per-app blocking without rooting or jailbreaking.

3. Monitor analytics

- These apps often include analytics dashboards showing blocked domains and traffic stats.

Laptop firewalls and advanced controls

1. Windows Defender Firewall

- Control Panel → System and Security → Windows Defender Firewall → Advanced Settings → Inbound/Outbound Rules → Create custom rules to restrict apps or ports.

2. macOS Application Firewall

- System Settings → Network → Firewall → Options → Add applications and choose Block incoming connections.

3. Advanced Users: Host-based firewalls

- Install tools like Little Snitch (macOS) or Windows Sysinternals PortMon to visualize and block connections at a granular level.

Reinforcing sandboxing and containerization

Sandboxing confines applications to restricted environments, preventing them from accessing unauthorized resources. Containerization takes this further by isolating entire workflows or sets of apps.

Android work profiles and secure folders

1. Set up a Work Profile

- Using Android Enterprise or apps like Island, create a separate “Profile” with its own data silo for corporate or sensitive apps.